

Clase 336 — OSINT y auditoría web con agentes de IA

Parte: **18 — IA aplicada a la ciberseguridad** · Fuente: kali-mcp (MIT) · OWASP WSTG 🕒 Duración estimada: **100 min** · Nivel: **Avanzado**

⚠️ **Solo objetivos autorizados/propios.** El OSINT se limita a información pública y a objetivos autorizados; la auditoría web, a aplicaciones tuyas o con permiso escrito.

🎯 Objetivo

Ver cómo un agente de IA acelera dos tareas muy repetitivas —**OSINT** (recolección de información de fuentes abiertas) y **auditoría web**— coordinando herramientas y sintetizando resultados, y cómo el profesional filtra el ruido, evita falsos positivos y respeta la legalidad.

📄 Resultados de aprendizaje

Al finalizar, el alumno podrá:

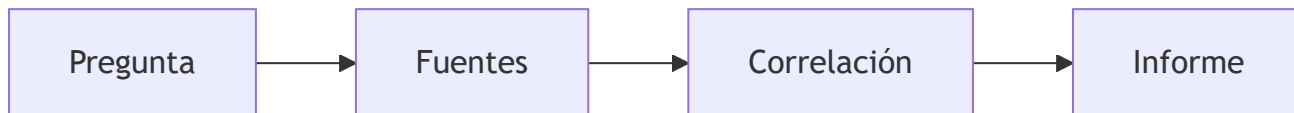
- 1. **Coordinar** un flujo de OSINT autorizado con apoyo de un agente.
- 2. **Ejecutar** una auditoría web asistida (descubrimiento, fingerprinting, checks OWASP) sobre una app propia.
- 3. **Filtrar** falsos positivos que la IA presenta como hallazgos.
- 4. **Respetar** los límites legales y de privacidad del OSINT.
- 5. **Sintetizar** los resultados en evidencia utilizable.

📖 Temas

#	Tema	Por qué importa
1	OSINT asistido (kali-osint)	La IA correlaciona fuentes públicas rápidamente.
2	Límites legales del OSINT	Público no es sinónimo de "todo vale"; hay privacidad.
3	Auditoría web (kali-web-audit, kali-wp-audit)	Fingerprinting y checks OWASP automatizados.
4	Falsos positivos	Los escáneres (y la IA) sobre-reportan; hay que validar.
5	Síntesis de evidencia	Convertir ruido en hallazgos accionables.

Explicación en profundidad

Un agente OSINT puede propagar homónimos y una auditoría web puede seguir enlaces fuera de alcance. Las fuentes conservan procedencia, las entidades mantienen alternativas y cada navegación valida dominio y método.



El diagrama separa lenguaje de autoridad. El modelo puede proponer; la política determina si la operación pertenece al alcance; la herramienta produce evidencia; y una persona o control determinista decide transiciones de alto impacto. Se registran prompt relevante, parámetros validados, versión, salida, aprobador y cleanup sin almacenar secretos innecesarios.

Caso razonado

Dos perfiles comparten alias. El agente mantiene nodos separados hasta encontrar evidencia independiente.

Glosario operativo

Término	Definición
Entity resolution	Evaluación de si registros representan la misma entidad.
Guardrail	Capa que reduce una capacidad o detecta su uso; no garantía absoluta.
Audit trail	Registro ordenado de solicitudes, decisiones, ejecuciones y resultados.

Criterio de dominio

El alumno demuestra dominio cuando reproduce el flujo completo, puede atribuir cada acción, evita que texto no confiable otorgue autoridad y explica qué control contiene un fallo del modelo.

Definiciones y características

OSINT (Open Source Intelligence) : Inteligencia obtenida de fuentes públicas. Característica clave: es legal recolectar lo público, pero su **uso** y la **privacidad** tienen límites.

Fingerprinting web : Identificar tecnologías, versiones y CMS de una aplicación (p. ej. WordPress y sus plugins) para orientar la auditoría.

Falso positivo : Hallazgo reportado que no es explotable o no existe. La IA, como los escáneres, los produce; validarlos es parte del trabajo.

Síntesis de evidencia : Reducir grandes salidas a los hechos verificables y relevantes para el informe.

Herramientas y preparación

kali-mcp con los flujos de OSINT y auditoría web, contra una **app propia** (p. ej. el **lab appsec-web** o un WordPress de laboratorio). Herramientas orquestadas típicas: whatweb, gobuster/ffuf, nikto, wpscan.

Laboratorio guiado

1. **OSINT de dominio propio.** Pide al agente un resumen de la huella pública de un dominio **tuyo** y verifica cada dato (DNS, subdominios) a mano.
2. **Fingerprinting.** Sobre tu app de laboratorio, ejecuta el flujo de auditoría web y revisa la tecnología detectada.
3. **Checks OWASP.** Deja que el agente proponga posibles problemas (cabeceras, versiones) y clasifícalos en confirmado / a verificar / falso positivo.
4. **Validación.** Confirma manualmente 3 hallazgos con Burp/curl.
5. **Evidencia.** Redacta 3 hallazgos con su evidencia reproducible.

Ejercicios

1. ¿Dónde está el límite legal/ético del OSINT sobre personas?
2. Da un ejemplo de falso positivo típico de un escáner web.
3. ¿Cómo confirmarías una cabecera de seguridad ausente que reporta el agente?
4. Diseña el flujo mínimo de una auditoría web asistida sobre tu app.
5. ¿Qué datos de OSINT no incluirías en un informe por privacidad?

Reto verificable

Realiza una auditoría web asistida sobre tu app de laboratorio y entrega 3 hallazgos validados manualmente + descarta explícitamente 2 falsos positivos que reportó el agente.

Criterio de aceptación: los 3 hallazgos son reproducibles; explicas por qué los otros 2 no son explotables; todo el trabajo fue sobre un objetivo propio/autorizado.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Tomar cada hallazgo del escáner como real	Sobre-reporte. Valida antes de incluirlo.
Hacer OSINT intrusivo o sobre personas sin base	Cruza líneas legales/éticas. Limitate a lo público y pertinente.
Auditar una web que no es tuya "para probar"	Ilegal sin permiso. Usa tu laboratorio.
Confiar en versiones detectadas sin confirmar	El fingerprinting se equivoca; verifica.

Preguntas frecuentes

? ¿La IA encuentra vulnerabilidades web sola? Encuentra *indicios* y los resume; confirmarlos y descartar falsos positivos es tu trabajo. Sin validación, un informe lleno de falsos positivos destruye tu credibilidad.

❓ **¿El OSINT con IA es legal?** Recolectar información pública suele serlo, pero el uso, la privacidad y la finalidad tienen límites legales que debes respetar (ver Parte 12 y clase 339).

Referencias

- [OWASP Web Security Testing Guide \(WSTG\)](#)
- kali-mcp (MIT) — <https://github.com/pabperez/kali-mcp>
- Parte 4 (web) y Parte 12 (OSINT) del programa.

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

Clase 335 — Explotación y post-explotación autorizada asistida por IA

Siguiendo clase

Clase 337 — IA para el lado defensivo: SOC, triaje y forense